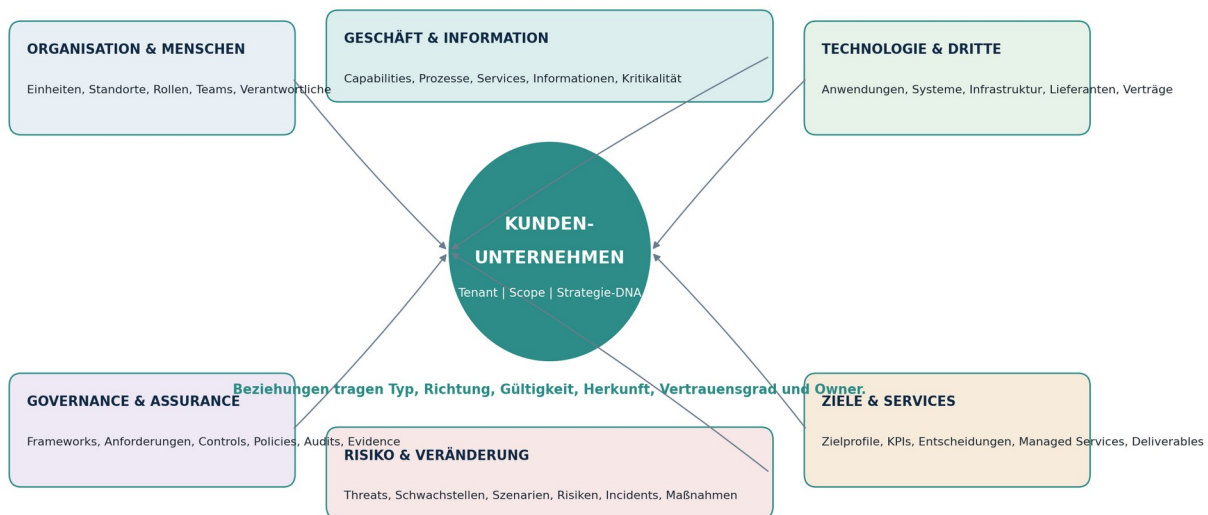


Digitaler Unternehmenszwilling & Informationsgraph

Kanonisches Objekt-, Beziehungs-, Historien- und Vertrauensmodell für Entscheidungen, ISMS-Betrieb und skalierbare Managed Services.

Objektökosystem: eine Unternehmenswahrheit, viele fachliche Perspektiven

Jede Familie besitzt eigene Regeln, wird aber über explizite Beziehungen mit dem gemeinsamen Unternehmenskontext verbunden.



ARBEITSBEZEICHNUNG ISMS Managed Service Platform

VERSION 1.0 | STATUS Erstellt | STAND 21.07.2026

ABHÄNGIGKEITEN Dokument 00 bis 06

Dokumentauftrag & Verbindlichkeit

Dokument 07 definiert die fachliche Wahrheit hinter allen Oberflächen, Prozessen, Reports, Simulationen und Managed Services. Es legt fest, welche Objekte und Beziehungen kanonisch sind, wie Historie und Herkunft gespeichert werden und wie Unsicherheit sichtbar bleibt. Die konkrete Datenbank- und Cloudarchitektur folgt in Dokument 18.

ENTSCHEIDUNG

Der digitale Unternehmenszwilling ist keine einzelne Grafik. Er ist der versionierte semantische Kern der Plattform und bleibt stabil, auch wenn Oberflächen, Integrationen oder Speichertechnologien wechseln.

Dokumentensteuerung

Merkmal	Festlegung
Zweck	Kanonisches Objekt-, Beziehungs-, Zeit- und Vertrauensmodell
Owner	Produktarchitektur / Datenmodell / ISMS-Fachlichkeit
Abhängigkeiten	Dokument 00 bis 06
Folgedokumente	08, 09, 10, 17, 18 und 19
Änderungsregel	Neue Kernobjekte, Beziehungstypen oder globale Semantik benötigen Decision Record und Schema-Version.
Quelle der Wahrheit	Markdown-Datei 07 im Repository; PDF/DOCX sind geprüfte Lesefassungen.

Inhalt

1 Auftrag · 2 Executive Summary · 3 Prinzipien · 4 Definition · 5 Schichten · 6 Objektkatalog · 7 Identität · 8 Lebenszyklus · 9 Beziehungen · 10 Objekt-360 · 11 Zeit · 12 Vertrauen · 13 Ingestion · 14 Konflikte · 15 Kausalität · 16 Abfragen · 17 Sicherheit · 18 APIs · 19 Szenarien · 20 Demo · 21 Akzeptanz · 22-25 Governance

1. Executive Summary

Der Zwilling bildet nicht jede technische Einzelheit des Unternehmens nach. Er modelliert gezielt jene Strukturen, Abhängigkeiten, Kontrollen, Risiken, Entscheidungen und Services, die für Informationssicherheit und Governance relevant sind. Dadurch kann die Plattform statt bloßer Listen erklären: Warum ist ein Risiko hoch? Welche Geschäftsprozesse wären betroffen? Welche Control wirkt tatsächlich? Welche Entscheidung wurde auf welcher Datenbasis getroffen?

DIE KERNIDEE

Eine Unternehmenswahrheit entsteht nicht durch einen einzigen Score, sondern durch stabile Identitäten, explizite Beziehungen, nachvollziehbare Zeitstände, sichtbare Herkunft und menschliche Verantwortung.

2. Grundprinzipien - Teil 1

- P01 - Semantik vor Speichertechnik: Der Objekt- und Beziehungsvertrag ist fachlich kanonisch; ob relational, graphbasiert oder hybrid gespeichert wird, bleibt Dokument 18 vorbehalten.
- P02 - Stabile Identität: Objekte behalten eine unveränderliche ID über Namens-, Owner-, System- und Statuswechsel hinweg.
- P03 - Beziehungen sind erstklassige Daten: Jede relevante Beziehung besitzt Typ, Richtung, Gültigkeit, Quelle, Vertrauensgrad und ggf. Owner.
- P04 - Historie wird nicht überschrieben: Freigegebene Zustände, Entscheidungen und Nachweise bleiben rekonstruierbar.
- P05 - Beobachtung, Ableitung und Entscheidung trennen: Importierte Fakten, berechnete Aussagen und menschliche Freigaben werden getrennt gespeichert und dargestellt.
- P06 - Eine Wahrheit, mehrere Perspektiven: Rollen sehen unterschiedliche Verdichtung, nicht unterschiedliche Datenrealitäten.

2. Grundprinzipien - Teil 2

- P07 - Unsicherheit ist sichtbar: Datenlücken, Konflikte, veraltete Quellen und Modellannahmen werden nicht in einem Score versteckt.
- P08 - Kausalität nur mit Begründung: Wirkungswege tragen Regelversion, Annahmen und Vertrauen; bloße Korrelation wird nicht als Ursache dargestellt.
- P09 - Mandantentrennung ohne Metadatenleck: Auch Suche, Counts, Graphkanten, Exporte und Fehlertexte dürfen keine fremden Objekte verraten.
- P10 - Erweiterbar ohne Schema-Chaos: Branchenspezifische Objekte und Attribute verwenden versionierte Erweiterungspakete und Governance.
- P11 - Menschliche Verantwortung bleibt explizit: Owner, Entscheider, Reviewer und Serviceverantwortung sind fachliche Beziehungen, keine impliziten Nutzerfelder.
- P12 - Der Twin ist handlungsorientiert: Jedes Objekt kann in Entscheidung, Aufgabe, Workflow, Report, Service oder Auditkontext überführt werden.

3. Definition und bewusste Grenzen

Der digitale Unternehmenszwillings ist ein mandantenbezogenes, zeitabhängiges und erklärbares Modell aus Objekten, Beziehungen, Ereignissen, Quellen, Bewertungen und Entscheidungen. Er beschreibt den für ISMS, Resilienz und Servicebetrieb relevanten Ausschnitt der Realität.

NICHT-ZIEL

Der Twin ist kein CMDB-, SIEM-, Ticketing-, ERP- oder Data-Lake-Ersatz. Er integriert diese Systeme, übernimmt relevante Fakten und übersetzt sie in einen gemeinsamen Sicherheits- und Entscheidungskontext.

Modellierungstiefe

- Mindestkern: Organisation, Scope, Prozesse, Informationen, kritische Assets, Risiken, Controls, Maßnahmen, Evidence und Owner.
- Empfohlene Tiefe: Lieferanten, Services, Anforderungen, Tests, Audits, Ziele und Managed Services.
- Expertentiefe: Komponenten, Schnittstellen, Bedrohungsszenarien, bitemporale Historie, Regel- und Simulationsartefakte.

4. Fünfschichtige Vertrauensarchitektur

Der digitale Unternehmenszwilling als fünfteilige Vertrauensarchitektur

Nicht eine Grafik, sondern ein lebendes, versioniertes und erklärbares Modell des Unternehmens.



Der semantische Vertrag bleibt stabil, auch wenn Speichertechnologie, Integrationen oder Oberflächen wechseln.

Die Schichten trennen Nutzererlebnis, Semantik, Zeit/Vertrauen, Datenaufnahme und technische Persistenz. Dadurch kann die Plattform wachsen, ohne dass jede neue Integration oder Datenbankentscheidung die fachliche Wahrheit verändert.

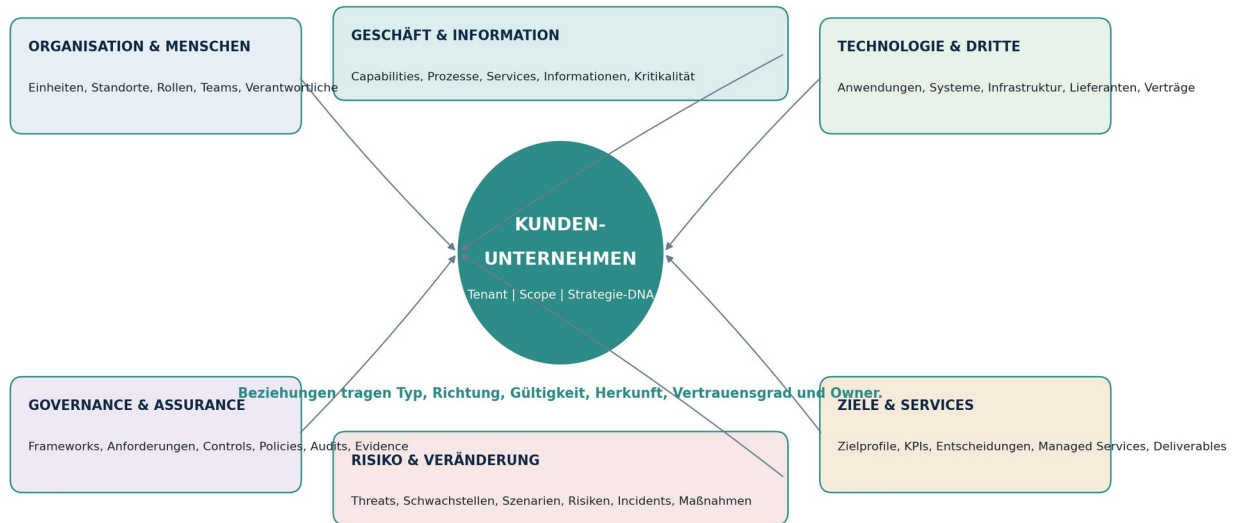
ARCHITEKTUR EGEL

Dokument 07 definiert das fachliche Modell. Dokument 18 darf die technische Umsetzung optimieren, aber weder Identität noch Beziehungssinn oder Historienregeln unbemerkt verändern.

5. Objektökosystem

Objektökosystem: eine Unternehmenswahrheit, viele fachliche Perspektiven

Jede Familie besitzt eigene Regeln, wird aber über explizite Beziehungen mit dem gemeinsamen Unternehmenskontext verbunden.



5.1 Kanonische Objektfamilien - Teil 1

ID / Familie	Kernobjekte	Leitfrage
F01 Tenant & Unternehmenskontext	Tenant, Organisation, Rechtseinheit, ISMS-Scope, Ausschluss, Strategie-DNA	Abgrenzung der Daten, Ziele und Verantwortung.
F02 Organisation & Verantwortung	Organisationseinheit, Standort, Team, Person, Produktrolle, fachliche Rolle, Vertretung	Wer trägt wofür Verantwortung und in welchem Kontext?
F03 Geschäft & Information	Business Capability, Geschäftsprozess, Produkt/Service, Information Asset, Datenklasse, Kritikalität	Was erzeugt Wert und was muss geschützt werden?
F04 Technologie & Infrastruktur	Anwendung, IT-Service, System, Komponente, Cloud-Ressource, Endpoint, Netzwerkzone, Schnittstelle	Welche technischen Abhängigkeiten tragen das Geschäft?

5.2 Kanonische Objektfamilien - Teil 2

ID / Familie	Kernobjekte	Leitfrage
F05 Dritte & Lieferkette	Lieferant, Unterauftragnehmer, Vertrag, externe Leistung, Datenverarbeitung, Abhängigkeit	Welche externen Parteien und Leistungen beeinflussen Sicherheit und Resilienz?
F06 Governance & Anforderungen	Framework, Requirement, Control Objective, Control, Control Implementation, Policy, Ausnahme	Welche Vorgaben gelten und wie werden sie umgesetzt?
F07 Risiko & Veränderung	Threat, Vulnerability, Weakness, Risk Scenario, Risk, Incident, Finding, Change Signal	Was kann passieren, warum und mit welcher Auswirkung?
F08 Arbeit, Nachweis & Assurance	Measure, Task, Evidence, Control Test, Assessment, Audit, Finding, Remediation	Was wird getan, geprüft und belegt?
F09 Ziele, Entscheidungen & Services	Target Profile, Objective, KPI, Decision Record, Managed Service, SLA, Deliverable, Review	Wohin soll sich das Unternehmen entwickeln und wer unterstützt dabei?

Objektkatalog als versionierter Vertrag

Jeder Typ besitzt Definition, Pflichtattribute, erlaubte Status, Beziehungsmuster, Validierungsregeln, Standardansichten und Migrationsregeln. Branchenpakete dürfen den Katalog erweitern, aber Kernbegriffe nicht still umdeuten.

BEISPIEL

Ein "System" darf nicht bei einem Kunden eine Anwendung und bei einem anderen einen Geschäftsprozess bedeuten. Unterschiedliche Bedeutungen benötigen unterschiedliche Typen oder sauber definierte Untertypen.

6. Objektvertrag, Identität und Metadaten - Teil 1

Die unveränderliche Objekt-ID trennt Identität von Namen, externen Schlüsseln und Versionen. Ein Asset bleibt dasselbe fachliche Objekt, auch wenn es umbenannt, migriert, einem neuen Owner zugeordnet oder stillgelegt wird.

Feld	Zweck	Regel
object_id	Unveränderliche, global eindeutige ID	Nie aus Namen oder externen IDs ableiten.
tenant_id	Primäre Mandantenzuordnung	Pflichtfeld; keine Cross-Tenant-Beziehung ohne freigegebenes Plattformobjekt.
object_type	Kanonischer Typ aus dem Objektkatalog	Versionierter Typvertrag.
display_name	Nutzerverständlicher Name	Änderbar; nicht identitätsstiftend.
description	Klartextzweck und Kontext	Optional, aber für kritische Objekte empfohlen.
lifecycle_status	Entwurf, aktiv, in Review, stillgelegt, archiviert	Typspezifische Status dürfen ergänzen, nicht widersprechen.
scope_ids	Geltende ISMS-/Service-/Audit-Scopes	Mehrfachzuordnung mit expliziter Gültigkeit.
owner_ids	Fachlicher und ggf. technischer Owner	Rolle und Gültigkeitszeitraum sind getrennt gespeichert.
IDENTITÄTSREGEL	Externe IDs sind Quellreferenzen, keine primäre Produktidentität. Ein Objekt kann mehrere Quell-IDs besitzen und bleibt auch bei Connectorwechsel stabil.	

6.1 Objektvertrag - Teil 2

Feld	Zweck	Regel
classification	Vertraulichkeit und Schutzbedarf	Steuert Anzeige, Export, Retention und Zugriff.
source_refs	Quellsystem, Import, Datei oder Nutzer	Mehrere Quellen mit Priorität möglich.
valid_time	Fachlich gültig von/bis	Unterstützt historische Wahrheit.
record_time	Im System erfasst/ersetzt am	Unterstützt Auditierbarkeit und bitemporale Abfragen.
version	Version des fachlichen Zustands	Wichtige Freigaben erzeugen unveränderbare Versionen.
quality_state	Vollständigkeit, Aktualität, Konsistenz, Review	Dimensionen statt nur Gesamtampel.
tags_custom_fields	Konfigurierbare Erweiterungen	Governed Schema; keine unkontrollierte Freitextdatenbank.

7. Lebenszyklus und Status

Status	Bedeutung
Entwurf	Noch nicht belastbar; darf nicht still in Managementberichte einfließen.
Beobachtet	Aus Quelle übernommen, aber fachlich noch nicht bestätigt.
Geprüft	Plausibilität, Scope und Beziehungen fachlich geprüft.
Freigegeben	Für den definierten Zweck verbindlicher Zustand.
In Änderung	Geplante oder laufende Änderung mit Übergangszustand.
Überholt	Durch neue Version ersetzt; historisch sichtbar.
Stillgelegt	Nicht mehr aktiv, aber für Historie und Abhängigkeiten relevant.
Archiviert	Außerhalb des Regelbetriebs; nur nach Berechtigung abrufbar.

8. Beziehungen als erstklassige Daten

Eine Beziehung ist nicht nur eine Linie im Diagramm. Sie ist ein versionierter fachlicher Datensatz mit Quelle, Ziel, Typ, Richtung, Gültigkeit, Herkunft, Status, Vertrauen und ggf. Owner. Assertierte, importierte, abgeleitete und freigegebene Beziehungen bleiben unterscheidbar.

GRUNDSATZ

Die generische Beziehung "related_to" darf nur temporär verwendet werden. Ein belastbares Zielmodell typisiert fachlich relevante Beziehungen.

Typ	Beispiel	Semantische Regel
R01 part_of	Organisationseinheit -> Organisation	Hierarchie; verhindert Zyklen innerhalb derselben Hierarchie.
R02 located_at	Asset/Team -> Standort	Physische oder primäre Betriebszuordnung.
R03 owns	Person/Rolle/Einheit -> Objekt	Fachliche Verantwortung mit Gültigkeitszeitraum.
R04 operates	Team/Lieferant -> System/Service	Operative Verantwortung; kann von Ownership abweichen.
R05 supports	Capability/Prozess/Asset -> Capability/Prozess	Unterstützungsbeziehung ohne harte Laufzeitabhängigkeit.
R06 depends_on	Prozess/Service/Asset -> Asset/Lieferant	Ausfall oder Qualitätsverlust kann Zielobjekt beeinträchtigen.
R07 processes	Prozess/System/Lieferant -> Information Asset	Datenverarbeitung mit Zweck und Datenklasse.
R08 exposes	Schwäche/Vulnerability -> Asset	Angriffs- oder Fehlermöglichkeit am Zielobjekt.
R09 threatens	Threat -> Risk Scenario/Asset	Relevante Bedrohung für einen konkreten Kontext.
R10 affects	Risk/Incident/Change -> Prozess/Information/Objective	Beschreibt mögliche oder bestätigte Wirkung.
R11 caused_by	Risk/Finding/Incident -> Ursache	Kausale Hypothese oder bestätigte Ursache, mit Vertrauensgrad.
R12 mitigates	Control/Measure -> Risk Scenario/Risk	Erwartete oder bestätigte Risikowirkung.

8.1 Kanonischer Beziehungskatalog - Teil 2

Typ	Beispiel	Semantische Regel
R13 implements	Control Implementation -> Control	Lokale Umsetzung eines generischen Controls.
R14 satisfies	Control/Evidence -> Requirement	Beitrag zur Anforderungserfüllung; partiell oder vollständig.
R15 evidences	Evidence -> Control/Measure/Decision	Nachweisbezug mit Zeitraum und Prüfstatus.
R16 tests	Control Test/Assessment -> Control Implementation	Prüft Design, Umsetzung oder Wirksamkeit.
R17 finds	Audit/Assessment -> Finding	Herkunft eines Findings.
R18 remediates	Measure -> Finding/Weakness	Behandelt konkrete Feststellung oder Schwäche.
R19 requires	Objective/Service/Audit -> Control/Measure/Evidence	Verbindliche Abhängigkeit im jeweiligen Scope.
R20 contributes_to	Measure/Control/Service -> Objective/KPI	Begründeter Wirkungsbeitrag ohne Garantie.
R21 delivered_by	Managed Service/Deliverable -> Provider Team	Delivery-Verantwortung und Servicekontext.
R22 covered_by	Object -> Managed Service/Contract	Zeigt, welche Objekte im Serviceumfang liegen.
R23 decided_in	Risk/Change/Service -> Decision Record	Verknüpft fachlichen Zustand mit menschlicher Entscheidung.
R24 supersedes	Version/Policy/Decision -> Vorgänger	Explizite Ablösung ohne historische Überschreibung.
R25 related_to	Objekt -> Objekt	Nur als zeitlich begrenzter Fallback; muss später typisiert werden.

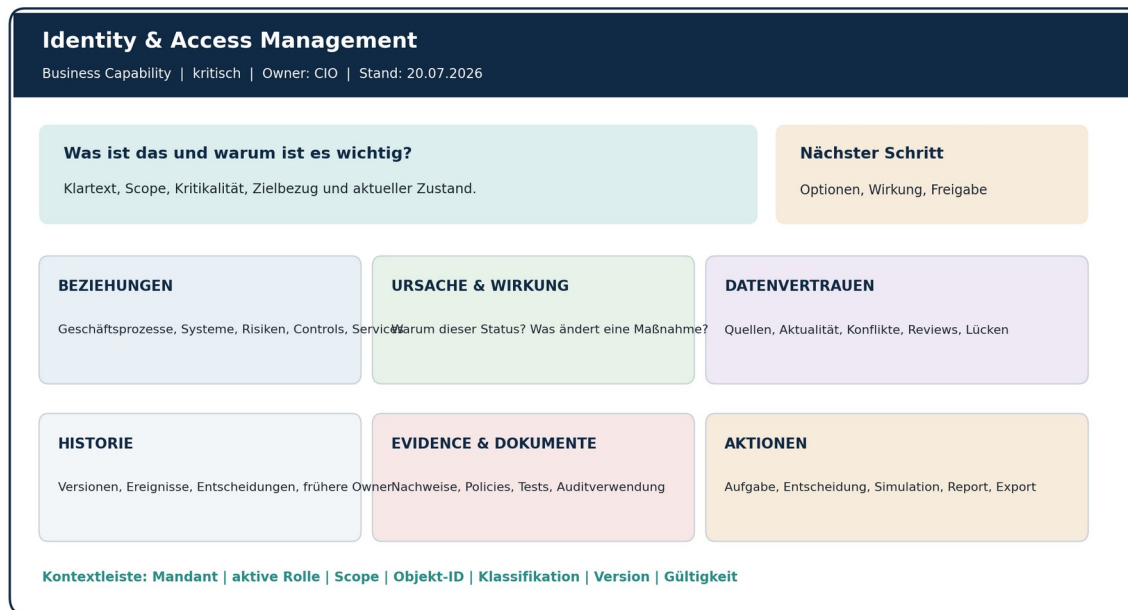
Kardinalität, Richtung und Zyklen

- Beziehungen haben eine kanonische Leserichtung; inverse Darstellung ist UI-Komfort, kein zweiter Datensatz.
- Hierarchische Beziehungen verbieten Zyklen; Netzwerkbeziehungen dürfen Zyklen besitzen, wenn fachlich sinnvoll.
- Kardinalitäten werden je Typ definiert und bei Importen als Warnung oder Fehler geprüft.
- Eine Beziehung kann zeitlich enden, ohne dass die historischen Objekte gelöscht werden.

9. Objekt-360 und Navigationsvertrag

Objekt-360: dieselbe Denklogik für Prozess, Asset, Risiko, Control oder Service

Ein Nutzer lernt eine Objektseite - und kann anschließend durch das gesamte Modell navigieren.



Objekt-360 ist die gemeinsame Interaktionslogik für Prozess, Information, Asset, Lieferant, Risiko, Control, Evidence, Audit, Entscheidung und Service. Rollen erhalten unterschiedliche Verdichtung, aber dieselben Objekt-IDs und dieselbe Historie.

Verbindliche Bereiche

- Identität und Kontext; Bedeutung und Zielbezug; Beziehungen und Abhängigkeiten; Ursache/Wirkung; Datenvertrauen; Historie und Versionen; Evidence/Dokumente; nächste sinnvolle Aktionen.

10. Zeitmodell, Versionierung und Ereignisse

Für Audits und Entscheidungen reicht ein einfaches "zuletzt geändert" nicht aus. Die Plattform trennt fachliche Gültigkeit von Systemerfassung. So lässt sich rekonstruieren, wie ein Objekt am Stichtag freigegeben war, welche Informationen damals bekannt waren und welche Korrekturen erst später eingingen.

Bitemporales Grundmuster

Dimension	Frage	Beispiel
Valid Time	Wann war die Aussage fachlich gültig?	Lieferantenvertrag gültig 01.01.-31.12.2027.
Record Time	Wann wurde sie im System erfasst oder ersetzt?	Nachtrag am 15.03.2027 eingespielt.
Version	Welcher freigegebene Zustand gilt für einen Zweck?	Policy v3.2 für Audit 2027.
Event	Was hat den Zustandswechsel ausgelöst?	Review, Import, Decision Record, Incident.
Snapshot	Welcher konsistente Stand speist Report oder Simulation?	Management Review Snapshot 2027-Q2.

NICHT ÜBERSCHREIBEN

Freigegebene Entscheidungen, Auditstände und Evidence-Verwendungen bleiben historisch erhalten. Korrekturen erzeugen neue Versionen oder rückwirkende Ereignisse mit Begründung.

11. Herkunft, Datenqualität und Vertrauen

Vertrauen ist zweckabhängig. Ein importierter Assetname kann für eine operative Suche genügen, aber nicht für eine Investitionssimulation. Deshalb werden Qualitätsdimensionen einzeln gespeichert und je Anwendungsfall gegen Mindestanforderungen geprüft.

Dimension	Kernfrage	Sichtbare Nachweise
Herkunft	Ist die Quelle bekannt, zulässig und nachvollziehbar?	Quelle, Connector, Importjob, Nutzer, Dokument, Extraktionsregel.
Aktualität	Ist die Information für den Zweck noch frisch genug?	Letzte Beobachtung, erwartete Frequenz, TTL, Stale-State.
Vollständigkeit	Sind Pflichtattribute und erwartete Beziehungen vorhanden?	Schema- und Scope-bezogene Regeln.
Konsistenz	Widersprechen sich Quellen, Status oder Beziehungen?	Konfliktregeln, Duplikate, Hierarchie- und Kardinalitätschecks.
Bestätigung	Wurde die Aussage fachlich geprüft oder freigegeben?	Ungeprüft, maschinell plausibilisiert, reviewed, freigegeben.
Verlässlichkeit	Wie belastbar ist Quelle oder Ableitungsregel?	Quellenklasse, Historie, Fehlerrate, Modell-/Regelversion.
Zweckeignung	Reicht die Qualität für diese Entscheidung oder diesen Report?	Kontextabhängiger Mindestschwellenwert statt Universalampel.
TRANSPARENZ	Ein Gesamtindikator darf die Dimensionen verdichten, aber nie verbergen. Nutzer können jede Bewertung bis zur Quelle, Regel und letzten menschlichen Prüfung öffnen.	

12. Dateneingang, Normalisierung und Synchronisation

Der Twin erhält Daten aus Workshops, manueller Pflege, Dateien, APIs, Konnektoren, Events und Evidence. Rohdaten werden unverändert referenziert; der kanonische Zustand entsteht durch nachvollziehbare Normalisierung, Matching, Validierung und Freigabe.

- 1. Aufnehmen - Quelle, Zeitpunkt, Lizenz- und Zweckkontext festhalten.
- 2. Normalisieren - Formate, Namen, Zeit, Klassifikation und Einheiten vereinheitlichen.
- 3. Identifizieren - externe ID, stabile Schlüssel und Matchkandidaten prüfen.
- 4. Validieren - Schema, Pflichtattribute, Kardinalität, Zyklen und Scope kontrollieren.
- 5. Beziehungen bilden - assertierte und abgeleitete Kanten getrennt erzeugen.
- 6. Konflikte markieren - widersprüchliche Quellen und Duplikate sichtbar machen.
- 7. Prüfen/Freigeben - Data Steward oder Owner bestätigt kritische Zustände.
- 8. Veröffentlichen - neue Version, Ereignis und abhängige Neuberechnungen auslösen.

Connector-Zustände

- verbunden / gesund; verzögert; teilweise; fehlerhaft; Berechtigung abgelaufen; Quelle entfernt; Daten veraltet; Re-Sync läuft.

FALLBACK

Generative KI kann Texte klassifizieren oder Matchkandidaten vorschlagen. Der Kernpfad bleibt mit Regeln, manueller Zuordnung und prüfbaren Imports funktionsfähig.

13. Matching, Dubletten, Konflikte und Stewardship

Die Plattform darf nicht still entscheiden, dass zwei ähnlich benannte Assets identisch sind. Sie nutzt eine abgestufte Matchingstrategie: exakte externe IDs, stabile Kombinationen, konfigurierbare Regeln und zuletzt heuristische Kandidaten mit Begründung.

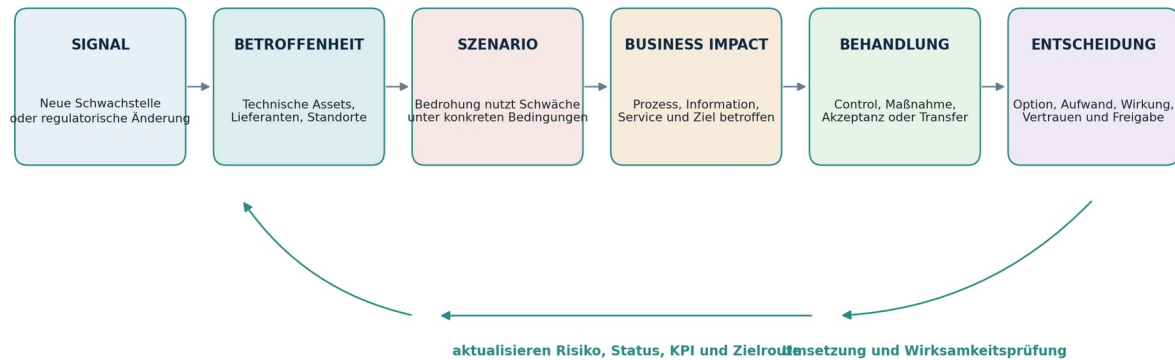
Konfliktklassen

Konflikt	Beispiel	Behandlung
Identität	Zwei Connectoren melden dasselbe System mit unterschiedlichen IDs.	Matchkandidat, Quellvergleich, Merge mit Undo.
Attribut	Kritikalität in Workshop hoch, in CMDB mittel.	Beide Quellen zeigen, Owner entscheidet oder Regel priorisiert.
Beziehung	Lieferant laut Vertrag Owner, laut Betrieb nur Operator.	Beziehungstypen und Gültigkeit getrennt prüfen.
Zeit	Stilllegung rückwirkend gemeldet.	Valid Time korrigieren, Record Time beibehalten.
Scope	Objekt in Audit-, aber nicht ISMS-Scope.	Mehrfachscope und Zweckbezug statt globalem Status.
Klassifikation	Evidence niedriger eingestuft als zugehörige Datenklasse.	Strengere Regel, Review und Exportblocker.
GOLDEN RECORD	Der kanonische Zustand ist eine begründete, versionierte Sicht auf mehrere Quellen. Quellen bleiben erhalten; Merge, Split und Override werden protokolliert und soweit möglich reversibel gestaltet.	

14. Kausalität, Betroffenheit und Wirkungspropagation

Kausalitäts- und Wirkungsweg: vom Signal zur verantwortbaren Entscheidung

Die Plattform zeigt nicht nur einen Score, sondern den nachvollziehbaren Pfad, über den eine Veränderung Wirkung erzeugt.



Jeder Knoten nennt Quelle, Gültigkeit, Regelversion, Unsicherheit und menschliche Bestätigung.

Die Plattform unterscheidet potenzielle Betroffenheit, bestätigte Betroffenheit und tatsächlichen Impact. Propagation ist kein blindes Durchreichen von Ampelfarben. Jeder Schritt braucht eine Beziehung, Regel oder menschliche Bestätigung.

Stop-Regeln

- fehlende oder veraltete Daten; nicht unterstützter Beziehungstyp; unzureichender Vertrauensgrad; unklarer Scope; Berechtigungsgrenze; widersprüchliche Quellen; Regel-/Modellversion nicht freigegeben.

15. Abfragen, Suche und Perspektiven

Nutzer sollen den Twin nicht nur zeichnen, sondern konkrete Fragen beantworten. Graph, Liste, Tabelle, Timeline und Impact View greifen auf denselben Objektvertrag und dieselben Berechtigungen zu.

Kanonische Frageklassen

- Abhängigkeit: Welche kritischen Prozesse hängen von diesem System oder Lieferanten ab?
- Coverage: Welche Risiken besitzen keine wirksame Control oder keine aktuelle Evidence?
- Impact: Welche Ziele, Services und Audits ändern sich, wenn dieses Objekt ausfällt oder ersetzt wird?
- Historie: Wie sah der freigegebene Scope beim letzten Management Review aus?
- Verantwortung: Welche Objekte haben keinen gültigen Owner oder keine Vertretung?
- Qualität: Welche Entscheidungen beruhen auf veralteten oder widersprüchlichen Daten?
- Wiederverwendung: Welche Evidence deckt mehrere Controls, Requirements oder Audits ab?
- Service: Welche kritischen Objekte liegen im Managed-Service-Scope, aber außerhalb des vereinbarten SLA?

Gespeicherte Sichten

Gespeicherte Sichten enthalten Query, Filter, Scope, Sortierung, Darstellung, Rolle und Freigabestatus. Freigegebene Views können Reports und Missionen speisen; persönliche Views bleiben privat.

16. Mandantenfähigkeit, Rechte und Datenschutz

Der Tenant ist eine harte Sicherheitsgrenze. Objekt- und Beziehungssicherheit müssen identisch wirken: Eine verborgene Kante darf weder über Suche noch über Counts, Empfehlungen, Graphlayout, Exporte oder Fehlermeldungen verraten werden.

Sicherheitsprinzipien

- Tenant Isolation für Daten, Indizes, Caches, Events, Dateien und Backups.
- Zugriff nach Rolle, Scope, Objekt, Beziehung, Attribut, Auftrag und Zweck.
- Plattformreferenzen wie Frameworks oder öffentliche Threats sind getrennt versioniert und read-only eingebunden.
- Supportzugriff ist genehmigt, zeitlich begrenzt, protokolliert und standardmäßig ohne Inhaltszugriff.
- Personenmodellierung minimiert Attribute; Teams und Rollen werden bevorzugt.
- Klassifikation vererbt sichere Mindestanforderungen an Evidence, Exporte und abgeleitete Artefakte.
- Löschung und Retention berücksichtigen Historie, rechtliche Pflichten, Decision Records und Exit Packages.

PRIVACY BY DESIGN

Der Twin modelliert Verantwortlichkeit, nicht unnötige Mitarbeiterüberwachung. Aktivitätsdaten dürfen nicht ohne klaren Zweck zu personenbezogenen Leistungsrankings werden.

17. APIs, Events und Erweiterbarkeit

Der semantische Vertrag wird über versionierte APIs und Events zugänglich. Integrationen dürfen nicht direkt interne Tabellenlogik voraussetzen, sondern arbeiten mit kanonischen Typen, IDs, Schemas und Beziehungscodes.

Baustein	Funktion	Leitplanke
Object API	Lesen, anlegen, ändern, versionieren, archivieren.	Tenant, ETag/Version und Validierung sind Pflicht.
Relationship API	Kanten anlegen, beenden, prüfen, erklären.	Typkatalog und Berechtigung gelten zentral.
Query API	Filter, Pfade, Impact, Aggregation, Timeline.	Kostenlimits, Pagination, keine Datenlecks.
Import API	Batch, Dry Run, Fehlerbericht, Mapping.	Idempotenz, Herkunft und Rollback.
Event Stream	ObjectChanged, RelationChanged, ReviewDue, ConflictRaised.	Versioniert, replaybar, tenantsoliert.
Schema Registry	Typen, Attribute, Beziehungen, Validation, Migrations.	Governance und Kompatibilitätsprüfung.
Export	JSON/CSV/Graph/Exit Package.	Scope, Klassifikation, Historie und Provenance erhalten.
Extension Pack	Branche, Framework, Workflow, Visualisierung.	Namensräume, Tests, Signatur und Deinstallation.

TECHNOLOGIEOFFEN

Graphdatenbank, relationale Datenbank, Suchindex und Event Store sind technische Entscheidungen. Der fachliche Vertrag dieses Dokuments darf dadurch nicht fragmentiert werden.

18. End-to-End-Szenarien

Neue Schwachstelle

Signal -> Asset Matching -> Szenario -> Prozessimpact -> Controlprüfung -> Decision Record -> Maßnahme/Service -> Wirksamkeitsprüfung.

Audit

Scope -> Requirements -> Controls -> Evidence -> Sampling -> Finding -> Remediation -> historischer Abschlussstand.

Lieferantenausfall

Lieferant -> externe Services -> Anwendungen -> Geschäftsprozesse -> Ziele -> Notfalloptionen und Managemententscheidung.

Scope Change

neue Einheit -> Datenimport -> Beziehungsprüfung -> Risikobaseline -> Zielroute -> Service- und Reportanpassung.

Policy Change

neue Version -> betroffene Requirements/Controls -> Lesebestätigung -> Evidence Review -> Audit- und Reportstatus.

Managed Service Aktivierung

Bedarf -> Service Charter -> covered_by-Beziehungen -> Workflow -> Deliverables -> KPI/Wertnachweis -> Service Review.

19. Synthetische Demo-Graphen

Vier Organisationen bilden unterschiedliche Komplexität und Regulatorik ab: Nordwerk Manufacturing SE, Finovia Digital Bank AG, MediCore Health Services GmbH und Consulting Operator Demo. Die Daten sind vollständig erfunden, aber fachlich konsistent und miteinander verknüpft.

- mindestens 10 Geschäftsprozesse, 25-50 relevante Assets und 8-15 Lieferanten je Kundentenant;
- Risiko-, Control-, Evidence-, Audit- und Serviceketten mit Historie;
- mindestens ein Datenkonflikt, eine veraltete Quelle und ein erklärbarer Trust-State;
- mehrere Rollenansichten auf denselben Objekt-IDs;
- keine nichtöffentlichen PwC-Daten, internen Preise oder geschützten Vorlagen.

20. Globale Akzeptanzkriterien

- Jedes Kernobjekt besitzt stabile ID, Tenant, Typ, Status, Scope, Owner, Quelle, Klassifikation und Historie.
- Jede sichtbare Beziehung zeigt Typ, Richtung, Gültigkeit und Herkunft; kritische Beziehungen zusätzlich Vertrauensgrad und Reviewstatus.
- Ein Nutzer kann von Prozess zu Asset, Risiko, Control, Evidence, Maßnahme, Entscheidung und Service navigieren, ohne den Kontext zu verlieren.
- Die Plattform kann einen freigegebenen Stichtagszustand rekonstruieren und spätere Korrekturen davon unterscheiden.
- Importierte, manuelle, abgeleitete und freigegebene Aussagen sind visuell und technisch unterscheidbar.
- Datenlücken, Konflikte und veraltete Quellen werden nicht still in Scores oder Reports verborgen.
- Ein Objekt kann mehrere Quellen besitzen; Konflikt und Quellpriorität sind nachvollziehbar.
- Kausalitätswege nennen Regelversion, Input-Snapshot, Annahmen und menschliche Bestätigung.
- Graph- und Listenansicht liefern dieselbe fachliche Wahrheit und dieselben Berechtigungsgrenzen.
- Cross-Tenant-Daten werden weder über Suche, Counts, Kanten, Exporte noch Fehlermeldungen geleakt.
- Personenbezogene Daten sind auf den fachlich erforderlichen Mindestumfang beschränkt.
- Schema-Erweiterungen sind versioniert, testbar und ohne unkontrollierte Custom-Field-Erosion möglich.
- Die vier synthetischen Demo-Organisationen besitzen konsistente Objekt-, Risiko-, Control-, Audit- und Serviceketten.
- Kritische Änderungen erzeugen Version, Ereignis, Audit Trail und ggf. neuen Reviewbedarf.
- Kernfunktionen des Twins bleiben ohne generative KI nutzbar.

21. Verbindliche Entscheidungen - Teil 1

ID	Entscheidung
07-D01	Der digitale Unternehmenszwillings ist das kanonische fachliche Modell der Plattform und keine optionale Visualisierung.
07-D02	Der Informationsgraph ist ein semantischer Vertrag unabhängig von der später gewählten Datenbanktechnologie.
07-D03	Jedes Objekt besitzt stabile ID, Tenant, Typ, Status, Scope, Owner, Klassifikation, Historie, Quelle und Qualitätszustand.
07-D04	Beziehungen werden als eigenständige, versionierte Datensätze mit Typ, Richtung, Gültigkeit, Quelle und Vertrauen modelliert.
07-D05	Assertierte, importierte, abgeleitete und menschlich freigegebene Aussagen werden getrennt gekennzeichnet.
07-D06	Freigegebene historische Zustände werden nicht überschrieben; Änderungen erzeugen Versionen und Ereignisse.
07-D07	Fachliche Gültigkeit und Zeitpunkt der Systemerfassung werden getrennt gespeichert, damit historische Sichtweisen rekonstruierbar sind.
07-D08	Graph und Listen-/Tabellensichten sind gleichwertige Zugänge; kein Kernworkflow darf eine Graphvisualisierung voraussetzen.
07-D09	Kausalitäts- und Wirkungsbeziehungen sind erklärbar und dürfen nur mit expliziter Regel, Quelle oder menschlicher Bestätigung propagieren.

21. Verbindliche Entscheidungen - Teil 2

ID	Entscheidung
07-D10	Ein Gesamtvertrauensscore darf nur als Verdichtung genutzt werden; Herkunft, Aktualität, Vollständigkeit, Konsistenz und Review bleiben einzeln sichtbar.
07-D11	Cross-Tenant-Beziehungen sind grundsätzlich verboten, außer zu versionierten Plattformreferenzen wie Frameworks oder öffentlichen Bedrohungsobjekten.
07-D12	Personenbezogene Daten werden minimiert; fachliche Rollen und Teams werden bevorzugt gegenüber unnötiger Einzelpersonenmodellierung.
07-D13	Jede kritische Objektseite folgt der Objekt-360-Logik: Kontext, Bedeutung, Beziehungen, Entwicklung, Vertrauen und nächster Schritt.
07-D14	Generische Beziehung `related_to` ist nur ein temporärer Import- oder Migrationszustand und kein Zielmodell.
07-D15	Abgeleitete Scores, Routen und Empfehlungen speichern Regel-/Modellversion, Input-Snapshot und Erklärungsartefakt.
07-D16	Die Demoumgebung verwendet logisch konsistente synthetische Graphen für vier Organisationen und mehrere Rollen.
07-D17	Datenkonflikte werden sichtbar verwaltet; die Plattform wählt nicht stillschweigend eine scheinbare Wahrheit.
07-D18	Die physische Speicher-, Such- und Eventarchitektur wird in Dokument 18 festgelegt, ohne den semantischen Vertrag dieses Dokuments zu verändern.

22. Begründete Annahmen

- 07-A01: Ein hybrides Persistenzmodell aus relationalen Daten, Suchindex, Objektspeicher und Graphzugriff ist wahrscheinlich sinnvoll.
- 07-A02: Die Mehrzahl der Kunden startet mit unvollständigen, widersprüchlichen und unterschiedlich aktuellen Daten.
- 07-A03: Konnektoren liefern sowohl stabile externe IDs als auch Daten, die nur heuristisch abgeglichen werden können.
- 07-A04: Framework- und Bedrohungsobjekte können als versionierte Plattformreferenzen mehreren Tenants bereitgestellt werden.
- 07-A05: Für kritische Daten braucht es fachliche Data Stewards oder Owner; Vollautomatisierung ist nicht belastbar.
- 07-A06: Objekttypen und Beziehungen werden im Laufe der Produktentwicklung erweitert, weshalb Migrationen und Schema-Versionen notwendig sind.
- 07-A07: Nicht jeder Kunde modelliert dieselbe Tiefe; Mindestkern, empfohlene Tiefe und Expertenmodell müssen unterschieden werden.
- 07-A08: Bitemporale Historie ist für Entscheidungen, Audits und rückwirkende Analysen wertvoll, erhöht aber technische Komplexität.
- 07-A09: KI kann Klassifikation, Matching und Zusammenfassung unterstützen, darf aber kritische Beziehungen nicht unbemerkt als Fakten setzen.
- 07-A10: Externe technische Assets können hohe Änderungsfrequenz haben und brauchen andere Lebenszyklen als Policies oder Organisationsobjekte.
- 07-A11: Rechte werden später tenant-, scope-, objekt-, beziehungs- und zweckbezogen differenziert.
- 07-A12: Synthetische Demo-Graphen dürfen Komplexität verdichten, müssen aber fachlich konsistent und eindeutig als Demo markiert sein.

23. Offene Fragen

- 07-O01: Welche Objekt- und Beziehungstypen sind für den ersten Build verbindlicher Mindestkern?
- 07-O02: Welche konkreten Kardinalitäts- und Zyklusregeln gelten je Beziehungstyp?
- 07-O03: Welche externe ID- und Matchingstrategie wird pro Konnektor verwendet?
- 07-O04: Wie wird bitemporale Historie technisch umgesetzt und für Nutzer verständlich dargestellt?
- 07-O05: Welche Datenqualitätsdimensionen fließen je Anwendungsfall in einen verdichteten Vertrauensindikator ein?
- 07-O06: Welche Plattformreferenzobjekte dürfen tenantübergreifend geteilt werden und wie erfolgt Versionierung?
- 07-O07: Welche personenbezogenen Attribute sind für Rollen, Audit und Evidence wirklich erforderlich?
- 07-O08: Wie werden große, kurzlebige Cloud- und Endpoint-Bestände aggregiert, ohne den Graph unbedienbar zu machen?
- 07-O09: Welche Konflikte dürfen automatisch nach Quellpriorität gelöst werden und welche benötigen menschliche Freigabe?
- 07-O10: Welche Kausalitätsregeln sind deterministisch, welche statistisch und welche rein fachlich bestätigt?
- 07-O11: Wie granular werden Evidence-Artefakte versioniert und gehasht?
- 07-O12: Welche Graphabfragen und gespeicherten Sichten müssen in der ersten Demo echt funktionieren?
- 07-O13: Wie werden Schema-Erweiterungen durch Branchenpakete genehmigt, getestet und migriert?
- 07-O14: Welche Exportformate bilden Objekte, Beziehungen, Historie und Provenance portabel ab?
- 07-O15: Wie werden Mandantenwechsel, Fusionen, Carve-outs und Serviceproviderwechsel im Twin modelliert?

24. Ideenparkplatz

Idee	Nutzenhypothese
Temporal Replay	Zeitregler, der zeigt, wie der Twin zu einem früheren Stichtag aussah und welche Informationen damals bekannt waren.
Graph Diff	Visueller Vergleich zweier Stände mit hinzugefügten, entfernten und geänderten Objekten sowie Auswirkungen.
Data Debt Map	Landkarte der Datenlücken, veralteten Quellen und ungeklärten Ownership mit geschätztem Entscheidungsrisiko.
Twin Health Mission	Tägliche Mission speziell zur Verbesserung von Datenqualität und Modellabdeckung.
Explain This Path	Ein Klick erklärt eine komplette Wirkungskette in Klartext und nennt alle Quellen und Annahmen.
Scope Sandbox	Änderungen am ISMS-Scope simulieren, ohne den freigegebenen Twin zu verändern.
Merger / Carve-out Mode	Zwei Unternehmensgraphen kontrolliert zusammenführen oder einen Teilgraphen ausgliedern.
Knowledge Pattern Library	Wiederverwendbare, anonymisierte Objekt- und Beziehungsmuster für Branchen und typische Architekturen.
Evidence Reuse Radar	Zeigt, welche Nachweise mehrere Controls, Audits oder Kundenanforderungen abdecken können.
Graph Copilot with Guardrails	Natürlichsprachige Abfragen, die nur auf berechnete, zitierbare Graphdaten zugreifen und Abfragen offenlegen.
Resilience Blast Radius	Schnelle Darstellung, welche Geschäftsprozesse und Ziele bei Ausfall eines Assets oder Lieferanten betroffen wären.
Twin Quality Benchmark	Vergleich der Modellqualität gegen einen definierten Mindestkern, nicht gegen andere Kunden ohne Einwilligung.

25. Änderungsprotokoll

Version	Datum	Status	Änderung
1.0	21.07.2026	Erstellt	Erstfassung aus Brainstorming und Dokument 00 bis 06.

Nächster Schritt

DOKUMENT 08

ISMS-Kernprozesse: Scope, Assets, Risiken, Controls, Maßnahmen, Policies, Evidence und Audits.